

PERFORMANCE WORK STATEMENT (PWS):

The contractor(s) shall provide medical and dental coding, auditing, and data entry for the various Service Units within the Phoenix Area Indian Health Service (PAIHS). The medical and dental coding, auditing, and data entry service will help the various Service Units comply with applicable federal and state laws, policies and regulations.

The Service Units that may utilize this contract include:

- Elko Service Unit in Elko, NV
- Utah-Ouray Service Unit in Ft. Duchesne, UT
- Hopi Health Care Center in Polacca, AZ
- Phoenix Indian Medical Center in Phoenix, AZ
- Whiteriver Service Unit, including Whiteriver and Cibecue, AZ
- Fort Yuma Health Center in Winterhaven, CA
- Colorado River Service Unit, including Parker, Peach Springs, AZ, Moapa, NV and Havasu Lake, CA
- Desert Visions Youth Wellness Center in Sacaton, AZ
- Nevada Skies Youth Wellness Center in Wadsworth, NV

BACKGROUND

To ensure proper reimbursement as well as regulatory compliance, the Centers for Medicare and Medicaid Services (CMS) and other federal, state and private payors have initiated precise guidelines for all providers. These guidelines include documentation requirements that demonstrate medical necessity, correct coding, and billing that depends on data integrity. The Office of Inspector General (OIG) of the United States Department of Health and Human Services (DHHS) believes that all participants in the Medicare and Medicaid programs have an ethical and legal duty to ensure the integrity of their transactions with CMS, Federal and State rules and regulations.

To ensure compliance with these directives, the Phoenix Area Office has initiated the Phoenix Area Medical and Dental Coding, Auditing, and Data Entry contract, which shall serve as a proactive step in evaluating the participating Service Units exposure to inadequate coding and data entry issues. Services performed by the Contractor(s) will permit the Phoenix Area to move toward strict adherence to CMS, Federal and State compliance guidelines and maintain consistency with the highest standards of business and professional ethics. Coding, auditing, and data entry compliance are key components of Medicare's conditions of participation in fostering and monitoring improved health care outcomes.

In the near future, as IHS moves forward to an enterprise wide Patient at the Heart (PATH) Electronic Health Record (EHR), the revenue cycle operations emphasis is on key staff positions such as coders to follow the standard IHS internal controls of timely completion. The goal is to stay current and prevent large coding backlogs that can require staff to work in a hybrid environment of the Resource Patient Management System (RPMS)/EHR and the PATH EHR. This could result in errors and delay in accurate patient data and revenue.

There may be times when various Service Units within the Phoenix Area will need the assistance of contractor(s) to keep their Outpatient and Inpatient Coding, Auditing, and Data Entry functions current. As this need arises, the Contractor(s) will be contacted to provide this service.

DESCRIPTION OF SERVICES:

A. Contractor(s) shall perform off-site comprehensive medical and dental coding, auditing, and data entry services for the various Service Units for Outpatient and Inpatient visits, based on Service Unit needs. Services shall be provided under the highest levels of integrity, compliance, and ethics to obtain the full financial reimbursement to which the Service Unit is legally entitled for services provided to IHS patients with third party resources. It is the Contractor's responsibility to be knowledgeable of all coding guidelines and to apply these to all patient encounters regardless of third-party resources.

B. The following services shall be required to be provided by the Contractor(s):

- a. Medical and Dental Coding: Capture of all appropriate information from the Electronic Health and Dental Record (EHR/EDR) for health data statistics, reimbursement and patient care purposes by assigning all proper and necessary ICD diagnosis and procedure codes, ADT, CPT, HCPCS, E/M codes, Modifiers and Trans-Codes.

- b. Data Entry: Enter information from the EHR/EDR Note or PCC paper form into the RPMS PCC Package ensuring that all data items specific to the individual visit are captured.
- c. Follow the Indian Health Manual, Part 5 – Management Services, Chapter 1 – Third- Party Revenue Accounts Management and Internal Controls, 5-1.3 Procedures F. Health Information Management Coding/Data Entry (1) Coding Timelines, all Outpatient visits assigned to the Contractor must be coded within 4 business days from the date of service and 10 business days from the date of discharge.
- d. Visits that are marked as Incomplete will be regularly monitored by the Contractor to ensure that the missing information being requested has been provided. The Contractor will charge the government only once for completing the visit, upon successful completion of the coding assignment.
- e. Only those visits that are assigned by the Service Unit HIM or Coding Supervisor will be processed by the Contractor.
- f. There may be times when there is more than one “item” displaying in the Coding Queue that belongs to a “visit”. The Contractor will only charge for the visit, not each item.

For example, an “item” may be ancillary services that belong to the “visit” but display separately in the Coding Queue. These “items” will all need to be merged to the “visit” and counted as one “visit.”

- g. When performing the Inpatient Coding function, visits that do not have all of the documentation provided in the Electronic Health Record (EHR) will be scanned to a private secure folder that will be shared by the contractor, COR and designated Service Unit personnel.
- h. Auditing of coding services may be requested by the Service Units. If requested, coding quality audits will be completed on a quarterly basis by identifying percentage of sampling, or by specific clinic or service of coded in the quarter will be reviewed to determine accurate code assignments including ICD, CPT, ADA, HCPCs, transcodes and E & M codes. Findings from these reviews will be utilized to improve coding and meeting ORAP Requirements for an outside coding auditor.

C. The IHS requires that services provided upon request of the Service Units continue without interruption during the term of this contract.

EXPERIENCE/ QUALIFICATIONS:

A. Contractor must have experience with the IHS’s computer system, Resource and Patient Management System (RPMS), which includes the use of the Patient Care Component (PCC) Package, Admission, Discharge and Transfer (ADT) Package and the Electronic Health Record (EHR) and Dental Record (EHR).

B. The contractor shall utilize qualified, experienced and credentialed professional staff to perform medical and dental coding and data entry services accurately and proficiently, and to adhere to applicable federal and state laws, regulations and policies.

- a. Credentialed staff shall be certified by the American Academy of Professional Coders (AAPC) or the American Health Information Management Association (AHIMA).
- b. Contractor shall require non-credentialed staff that is in training for certification by AAPC or AHIMA, to be supervised by a coder that is certified by at least one of these organizations.
- c. Contractor is to identify the minimum number of encounters their staff is responsible for completing on a daily basis. Specifically, the Contract shall provide the expected daily quota for one individual or per specialty for both Outpatient and Inpatient Coding.

C. While adhering to the IHS Privacy Act and Health Insurance Portability and Accountability Act (HIPAA) Privacy and Security policies and regulations, the Contractor shall access the IHS RPMS PCC data entry, EDR, EHR packages, and Vista Imaging. Access shall be through VPN connections through the Office of Information Technology (OIT) in Albuquerque, New Mexico.

REPORTING REQUIREMENTS:

A. The Government and Contractor(s) shall develop and maintain a data tracking log and process to ensure that all Coding Queue visits are accounted for and processed.

- a. The exact format of the Contractor's tracking log will be determined in consultation with the Government COR after the contract is awarded.

B. The Contractor(s) shall maintain a database and provide monthly volume and status reports to the COR. Reports shall include the number of visits received that month, which includes the number of visits that were marked as Reviewed/Complete and Incomplete. For those visits that were marked as Incomplete, the quantity and reason will be indicated.

C. The monthly volume and status reports shall be submitted with the Contractor's monthly invoice as provided for in the invoicing provisions of this contract.

- a. The exact format of the database will be determined in consultation with the Government COR after the contract is awarded.

QUALITY CONTROL:

A. The Contractor's quality control program shall integrate quality auditing, measurement method validation, and sample validation into the measurement process. The Contractor(s) shall outline how the quality control plan will be used to help deliver the highest possible quality results within committed resources, and also identify how often QA will be performed, the percentage of sampling that is done, the acceptable error rate for Contractor staff.

B. Quality Control shall also include the Contractor's turnaround time from the date the visit is received in the Contractor's queue to the date it is marked as Reviewed/Completed. Surveillance will be achieved through the Contractor's volume/status reports.

PRIVACY ACT INFORMATION AND BUSINESS ASSOCIATE AGREEMENT CLAUSE:

Contractor staff will have access to sensitive information covered under the Privacy Act and HIPAA. The Contractor shall prevent the unauthorized release of information obtained by staff during the performance of work required by this contract. The Contractor shall ensure that employees are aware of and receive as necessary training on all regulations and privacy and security laws such as the Privacy Act, HIPAA that restricts the release of information. The Contractor shall be required to comply with the Business Associate Agreement Clause and [Business Associate Agreement](#) included in this contract (See Section D).

SUBMISSION OF WORKLOAD INFORMATION AND INVOICES:

The Contractor(s) shall establish an invoicing process that details a breakdown of monthly services provided during the given month per the contract requirements. The invoice shall include a grand total for the amount due the contractor for all services provided. A proper invoice shall be in the format as specified in FAR 52.212-4 (g) Payment Documentation and Process.

Invoices shall be submitted as soon as possible after the last business day of the month, but not later than the 10th of the next month. It is imperative that invoicing timeframes be adhered to in order to prevent late or missed payments. Payment shall be made upon receipt of a proper invoice, Contractor's monthly status report (see the Reporting Requirements of this contract) and satisfactory contract performance.

COST & PRICE SCHEDULE:

The Contractor(s) shall furnish all necessary personnel, facilities, supplies, equipment and such other professional competence normally furnished to provide Coding and Data Entry services for the various Service Units within the Phoenix Area. Services shall be performed off-site at the Contractor's location.

This is a firm fixed-price, multi award blanket purchase agreement (BPA) to provide Coding and Data Entry functions for the PAIHS facilities during the specified contract period of performance. All stated volumes and quantities are estimates.

The offeror will submit a price and cost schedule for services to be performed during the contract term. The Offeror shall insert the unit prices for each of the services to be performed, as listed below.

Service description	Unit	Price per unit
---------------------	------	----------------

Inpatient coding	600	
Outpatient coding	165,000	
Inpatient auditing	80	
Outpatient auditing	4520	

PERIOD OF PERFORMANCE:

5/01/2026-09/30/2031 5-year BPA

CONTRACTING OFFICER'S REPRESENTATIVE (COR)

The Contracting Officer will designate in writing a COR who shall be responsible for:

- A. Monitoring the Contractor's technical progress, including the surveillance and assessment of performance and recommending to the Contracting Officer, changes in requirements;
- B. Interpreting scope of work;
- C. Performing technical evaluations required;
- D. Performing technical inspections and acceptances required by this contract;
- E. Monitoring funds available for obligation under this contract;
- F. Assisting the Contractor in the resolution of technical problems encountered during performance of this contract.

In no event is the COR empowered to change any of the terms and conditions of the contract. Changes in the scope of work, contract price, quantity, and quality or delivery schedule shall be made only by the Contracting Officer by properly executed modification to the contract.

The designation of a COR does not authorize or provide a legal right to change any kind of contractual terms regardless of the Contractor's apparent difficulties in fulfilling contract requirements.

HOMELAND SECURITY PRESIDENTIAL DIRECTIVE – 12 (HSPD-12)**Homeland Security Presidential Directive (HSPD)-12**

The Contractor (and/or any subcontractor) and its employees shall comply with Homeland Security Presidential Directive (HSPD)-12, *Policy for a Common Identification Standard for Federal Employees and Contractors*; OMB M-05-24; FIPS 201, *Personal Identity Verification (PIV) of Federal Employees and Contractors*; HHS HSPD-12 policy; and *Executive Order 13467, Part 1 §1.2*.

For additional information, see HSPD-12 policy at: <https://www.dhs.gov/homeland-security-presidential-directive-12>)

Roster. The Contractor (and/or any subcontractor) shall submit a roster by name, position, e-mail address, phone number and responsibility, of all staff working under this acquisition where the Contractor will develop, have the ability to access, or host and/or maintain a government information system(s). The roster shall be submitted to the COR and/or CO within *[OpDiv Specific timeline]* of the effective date of this contract. Any revisions to the roster as a result of staffing changes shall be submitted within *[OpDiv Specific timeline]* of the change. The COR will notify the Contractor of the appropriate level of investigation required for each staff member. *[If the OpDiv has an electronic template, include that information here along with a link, if applicable.]*

If the employee is filling a new position, the Contractor shall provide a position description and the Government will determine the appropriate suitability level.

The Homeland Security Presidential Directive 12 (HSPD-12) is the directive that was issued for “Policy for a Common Identification Standard for Federal Employees and Contractors”. HSPD-12 calls for all federal employees and contractors to use a standard smart credential to verify their identity for secure access to federal buildings and information systems.

HSPD-12 called upon the National Institute of Standards and Technology (NIST) to develop the actual technical standard, and the Office of Management and Budget (OMB) to manage implementation of the credentials. The uses of the credentials are left to the agencies themselves to decide.

The purpose of HSPD-12 is to provide a common reliable identification verification for government employees and contractors. It will help to protect against a variety of threats including:

- Unauthorized access to physical facilities or logical assets
- Improper issuance of valid credential to malicious holder
- Counterfeiting of credentials
- Intercept or probing to access stored information
- Successful cryptanalytic attacks against stored protected information
- Use of stolen or borrowed credential to gain access to physical or logical systems
- Intercept/technical surveillance to capture PIN(s)
- Use of credential issued for access to lower sensitivity/criticality assets to achieve access to more sensitive/critical assets

In compliance with HSPD-12, the Health and Human Services, Indian Health Service (IHS), Phoenix Area Office, establishes the requirement to evaluate and investigate all federal employees and contractor employees prior to issuing a Personal Identification Verification (PIV) card. Thus, all persons privileged to be employed in the Federal Government shall be reliable, trustworthy, of good conduct and character, and of complete and unwavering loyalty to the United States. This means that the placement of any contract employee under contract for secure access to information systems is subject to investigation.

The HSPD-2 link below covers the federal law requiring PIV cards for federal network access. A PIV card is required after the 120-waiver period, with no exceptions.

Homeland Security Presidential Directive 12: Policy for a Common Identification Standard for Federal Employees and Contractors <https://www.dhs.gov/homeland-security-presidential-directive-12>

It is a mandatory requirement that all IHS information system users must take annual security and privacy training in order to fulfill Federal mandates and regulations. In addition, all new users must successfully complete this course within 24 hours of on-boarding. Failure to complete training requirements will result in the loss of information systems access.

ADDENDUM TO CONTRACT CLAUSES:

This contract is covered under the terms and conditions of FSS/GSA Contract# GS-23F-0223P and the following addendum clauses:

I. Department of Health and Human Services Acquisition Regulation (HHSAR) (48 CFR Chapter 3) Clauses (Incorporated by Reference):

NUMBER	TITLE	DATE
352.223-70	SAFETY AND HEALTH	JAN 2006

A. Baseline Security Requirements

- 1) **Applicability.** The requirements herein apply whether the entire contract or order (hereafter “contract”), or portion thereof, includes either or both of the following:
 - a. Access (Physical or Logical) to Government Information: A Contractor (and/or any subcontractor) employee will have or will be given the ability to have, routine physical (entry) or logical (electronic) access to government information.
 - b. Operate a Federal System Containing Information: A Contractor (and/or any subcontractor) will operate a federal system and information technology containing data that supports the

HHS mission. In addition to the Federal Acquisition Regulation (FAR) Subpart 2.1 definition of “information technology” (IT), the term as used in this section includes computers, ancillary equipment (including imaging peripherals, input, output, and storage devices necessary for security and surveillance), peripheral equipment designed to be controlled by the central processing unit of a computer, software, firmware and similar procedures, services (including support services), and related resources.

- 2) **Safeguarding Information and Information Systems.** In accordance with the Federal Information Processing Standards Publication (FIPS)199, *Standards for Security Categorization of Federal Information and Information Systems*, the Contractor (and/or any subcontractor) shall:
- a. Protect government information and information systems in order to ensure:
 - **Confidentiality**, which means preserving authorized restrictions on access and disclosure, based on the security terms found in this contract, including means for protecting personal privacy and proprietary information;
 - **Integrity**, which means guarding against improper information modification or destruction, and ensuring information non-repudiation and authenticity; and
 - **Availability**, which means ensuring timely and reliable access to and use of information.
 - b. Provide security for any Contractor systems, and information contained therein, connected to an HHS network or operated by the Contractor on behalf of HHS regardless of location. In addition, if new or unanticipated threats or hazards are discovered by either the agency or contractor, or if existing safeguards have ceased to function, the discoverer shall immediately, **within one (1) hour or less**, bring the situation to the attention of the other party.
 - c. Adopt and implement the policies, procedures, controls, and standards required by the HHS Information Security Program to ensure the confidentiality, integrity, and availability of government information and government information systems for which the Contractor is responsible under this contract or to which the Contractor may otherwise have access under this contract. Obtain the HHS Information Security Program security requirements, outlined in the HHS Information Security and Privacy Policy (IS2P), by contacting the CO/COR or emailing fisma@hhs.gov.
 - d. Comply with the Privacy Act requirements and tailor FAR clauses as needed..
- 3) **Information Security Categorization.** In accordance with FIPS 199 and National Institute of Standards and Technology ([NIST Special Publication \(SP\) 800-60, Volume II: Appendices to Guide for Mapping Types of Information and Information Systems to Security Categories, Appendix C](#)), and based on information provided by the ISSO, CISO, or other security representative, the risk level for each Security Objective and the Overall Risk Level, which is the highest watermark of the three factors (Confidentiality, Integrity, and Availability) of the information or information system are the following:

Confidentiality:	☐ Low ☒ Moderate ☐ High
Integrity:	☐ Low ☐ Moderate ☐ High
Availability:	☐ Low ☐ Moderate ☐ High

Overall Risk Level: ☐ Low ☐ Moderate ☐ High

Based on information provided by the ISSO, Privacy Office, system/data owner, or other security or privacy representative, it has been determined that this solicitation/contract involves:

☐ No PII ☐ Yes PII

Complete this section using the information obtained from the Security and Privacy Checklist in Appendix A, parts A and B.

Personally Identifiable Information (PII). Per the Office of Management and Budget (OMB) Circular A-130, "PII is information that can be used to distinguish or trace an individual's identity, either alone or when combined with other information that is linked or linkable to a specific individual." Examples of PII include, but are not limited to the following: social security number, date and place of birth, mother's maiden name, biometric records, etc.

PII Confidentiality Impact Level has been determined to be: ☐ Low ☐ Moderate ☐ High

- 4) **Controlled Unclassified Information (CUI).** CUI is defined as "information that laws, regulations, or Government-wide policies require to have safeguarding or dissemination controls, excluding classified information." The Contractor (and/or any subcontractor) must comply with *Executive Order 13556, Controlled Unclassified Information, (implemented at 3 CFR, part 2002)* when handling CUI. 32 C.F.R. 2002.4(aa) As implemented the term "handling" refers to "...any use of CUI, including but not limited to marking, safeguarding, transporting, disseminating, re-using, and disposing of the information." 81 Fed. Reg. 63323. All sensitive information that has been identified as CUI by a regulation or statute, handled by this solicitation/contract, shall be:
- a. marked appropriately;
 - b. disclosed to authorized personnel on a Need-To-Know basis;
 - c. protected in accordance with NIST SP 800-53, *Security and Privacy Controls for Federal Information Systems and Organizations* applicable baseline if handled by a Contractor system operated on behalf of the agency, or NIST SP 800-171, *Protecting Controlled Unclassified Information in Nonfederal Information Systems and Organizations* if handled by internal Contractor system; and
 - d. returned to HHS control, destroyed when no longer needed, or held until otherwise directed. Destruction of information and/or data shall be accomplished in accordance with NIST SP 800-88, *Guidelines for Media Sanitization*.

- 5) **Protection of Sensitive Information.** For security purposes, information is or may be sensitive because it requires security to protect its confidentiality, integrity, and/or availability. The Contractor (and/or any subcontractor) shall protect all government information that is or may be sensitive in accordance with OMB Memorandum M-06-16, *Protection of Sensitive Agency Information* by securing it with a FIPS 140-2 validated solution.

See the HHS Standard for the Definition of Sensitive Information, for additional information in defining and protecting sensitive information.

- 6) **Confidentiality and Nondisclosure of Information.** Any information provided to the contractor (and/or any subcontractor) by HHS or collected by the contractor on behalf of HHS shall be used only for the purpose of carrying out the provisions of this contract and shall not be disclosed or made known in any manner to any persons except as may be necessary in the performance of the contract. The Contractor assumes responsibility for protection of the confidentiality of Government records and shall ensure that all work performed by its employees and subcontractors shall be under the supervision of the Contractor. Each Contractor employee or any of its subcontractors to whom any HHS records may be made available or disclosed shall be notified in writing by the Contractor that information disclosed to such employee or subcontractor can be used only for that purpose and to the extent authorized herein.

The confidentiality, integrity, and availability of such information shall be protected in accordance with HHS and [OpDiv] policies. Unauthorized disclosure of information will be subject to the HHS/[OpDiv] sanction policies and/or governed by the following laws and regulations:

- a. 18 U.S.C. 641 (Criminal Code: Public Money, Property or Records);
 - b. 18 U.S.C. 1905 (Criminal Code: Disclosure of Confidential Information); and
 - c. 44 U.S.C. Chapter 35, Subchapter I (Paperwork Reduction Act).
- 7) **Internet Protocol Version 6 (IPv6).** All procurements using Internet Protocol shall comply with OMB Memorandum M-05-22, *Transition Planning for Internet Protocol Version 6 (IPv6)*. .
- 8) **Government Websites.** All new and existing public-facing government websites must be securely configured with Hypertext Transfer Protocol Secure (HTTPS) using the most recent version of Transport Layer Security (TLS). In addition, HTTPS shall enable HTTP Strict Transport Security (HSTS) to instruct compliant browsers to assume HTTPS at all times to reduce the number of insecure redirects and protect against attacks that attempt to downgrade connections to plain HTTP. For internal-facing websites, the HTTPS is not required, but it is highly recommended.
- 9) **Contract Documentation.** The Contractor shall use provided templates, policies, forms and other agency documents [OpDiv specify which documents/forms will be provided to contractor] to comply with contract deliverables as appropriate.

See [Appendix D](#) for baseline deliverables.

10) Standard for Encryption. The Contractor (and/or any subcontractor) shall:

- a. Comply with the *HHS Standard for Encryption of Computing Devices and Information* to prevent unauthorized access to government information.
- b. Encrypt all sensitive federal data and information (i.e., PII, protected health information [PHI], proprietary information, etc.) in transit (i.e., email, network connections, etc.) and at rest (i.e., servers, storage devices, mobile devices, backup media, etc.) with FIPS 140-2 validated encryption solution.
- c. Secure all devices (i.e.: desktops, laptops, mobile devices, etc.) that store and process government information and ensure devices meet HHS and OpDiv-specific encryption standard requirements. Maintain a complete and current inventory of all laptop computers, desktop computers, and other mobile devices and portable media that store or process sensitive government information (including PII).
- d. Verify that the encryption solutions in use have been validated under the Cryptographic Module Validation Program to confirm compliance with [FIPS 140-2](#). The Contractor shall provide a written copy of the validation documentation to the COR *[OpDiv-provided delivery date]*.
- e. Use the Key Management system on the HHS personal identification verification (PIV) card or establish and use a key recovery mechanism to ensure the ability for authorized personnel to encrypt/decrypt information and recover encryption keys. Encryption keys shall be provided to the COR upon request and at the conclusion of the contract.

11) Contractor Non-Disclosure Agreement (NDA). Each Contractor (and/or any subcontractor) employee having access to non-public government information under this contract shall complete the OpDiv non-disclosure agreement. *[OpDiv inserted information/link should be cited here]*, as applicable. A copy of each signed and witnessed NDA shall be submitted to the Contracting Officer (CO) and/or CO Representative (COR) prior to performing any work under this acquisition.

See [Appendix C](#) for the HHS Contractor Non-Disclosure Agreement.

12) Privacy Threshold Analysis (PTA)/Privacy Impact Assessment (PIA) – The Contractor shall assist the OpDiv Senior Official for Privacy (SOP) or designee with conducting a PTA for the information system and/or information handled under this contract to determine whether or not a full PIA needs to be completed.

- a. If the results of the PTA show that a full PIA is needed, the Contractor shall assist the OpDiv SOP or designee with completing a PIA for the system or information within *[OpDiv to insert contract-specific timeline]* after completion of the PTA and in accordance with HHS policy and OMB M-03-22, *Guidance for Implementing the Privacy Provisions of the E-Government*

Act of 2002.

- b. The Contractor shall assist the OpDiv SOP or designee in reviewing the PIA at least every **three years** throughout the system development lifecycle (SDLC)/information lifecycle, or when determined by the agency that a review is required based on a major change to the system, or when new types of PII are collected that introduces new or increased privacy risks, whichever comes first.

A. Training

- 1) **Mandatory Training for All Contractor Staff.** All Contractor (and/or any subcontractor) employees assigned to work on this contract shall complete the applicable HHS/OpDiv Contractor Information Security Awareness, Privacy, and Records Management training (provided upon contract award) before performing any work under this contract. Thereafter, the employees shall complete *[OpDiv-specified]* Information Security Awareness, Privacy, and Records Management training at least **annually**, during the life of this contract. All provided training shall be compliant with HHS training policies.
- 2) **Role-based Training.** All Contractor (and/or any subcontractor) employees with significant security responsibilities (as determined by the program manager) must complete role-based training **annually** commensurate with their role and responsibilities in accordance with HHS policy and the *HHS Role-Based Training (RBT) of Personnel with Significant Security Responsibilities Memorandum*.
- 3) **Training Records.** The Contractor (and/or any subcontractor) shall maintain training records for all its employees working under this contract in accordance with HHS policy. A copy of the training records shall be provided to the CO and/or COR within **30 days** after contract award and **annually** thereafter or upon request.

B. Rules of Behavior

- 1) The Contractor (and/or any subcontractor) shall ensure that all employees performing on the contract comply with the *HHS Information Technology General Rules of Behavior*, and *[insert any OpDiv-specific rules, as applicable]*.
- 2) All Contractor employees performing on the contract must read and adhere to the Rules of Behavior before accessing Department data or other information, systems, and/or networks that store/process government information, initially at the beginning of the contract and at least **annually** thereafter, which may be done as part of annual OpDiv Information Security Awareness Training. If the training is provided by the contractor, the signed ROB must be provided as a separate deliverable to the CO and/or COR per defined timelines above.

C. Incident Response

The Contractor (and/or any subcontractor) shall respond to all alerts/Indicators of Compromise (IOCs) provided by HHS Computer Security Incident Response Center (CSIRC)/[OpDiv] IRT teams **within 24 hours**, whether the response is positive or negative.

FISMA defines an incident as “an occurrence that (1) actually or imminently jeopardizes, without lawful authority, the integrity, confidentiality, or availability of information or an information system; or (2) constitutes a violation or imminent threat of violation of law, security policies, security procedures, or acceptable use policies.. The HHS *Policy for IT Security and Privacy Incident Reporting and Response* further defines incidents as events involving cybersecurity and privacy threats, such as viruses, malicious user activity, loss of, unauthorized disclosure or destruction of data, and so on.

A privacy breach is a type of incident and is defined by Federal Information Security Modernization Act (FISMA) as the loss of control, compromise, unauthorized disclosure, unauthorized acquisition, or any similar occurrence where (1) a person other than an authorized user accesses or potentially accesses personally identifiable information or (2) an authorized user accesses or potentially accesses personally identifiable information for an other than authorized purpose. The HHS *Policy for IT Security and Privacy Incident Reporting and Response* further defines a breach as “a suspected or confirmed incident involving PII” .

In the event of a suspected or confirmed incident or breach, the Contractor (and/or any subcontractor) shall:

- 1) Protect all sensitive information, including any PII created, stored, or transmitted in the performance of this contract so as to avoid a secondary sensitive information incident with FIPS 140-2 validated encryption.
- 2) NOT notify affected individuals unless so instructed by the Contracting Officer or designated representative. If so instructed by the Contracting Officer or representative, the Contractor shall send [OpDiv] approved notifications to affected individuals [*insert OpDiv Specific timeline, process, and format*].
- 3) Report all suspected and confirmed information security and privacy incidents and breaches to the OpDiv Incident Response Team (IRT) [*OpDiv inserted contact information should be cited here*], COR, CO, OpDiv SOP (or his or her designee), and other stakeholders, including incidents involving PII, in any medium or form, including paper, oral, or electronic, as soon as possible and without unreasonable delay, no later than **one (1) hour**, and consistent with the applicable OpDiv and HHS policy and procedures, NIST standards and guidelines, as well as US-CERT notification guidelines. The types of information required in an incident report must include at a minimum: company and point of contact information, contract information, impact classifications/threat vector, and the type of information compromised. In addition, the Contractor shall:
 - a. cooperate and exchange any information, as determined by the Agency, necessary to effectively manage or mitigate a suspected or confirmed breach;
 - b. not include any sensitive information in the subject or body of any reporting e-mail; and

- c. encrypt sensitive information in attachments to email, media, etc.
- 4) Comply with OMB M-17-12, *Preparing for and Responding to a Breach of Personally Identifiable Information* HHS/OpDivHHS and [OpDiv] incident response policies when handling PII breaches.
- 5) Provide full access and cooperate on all activities as determined by the Government to ensure an effective incident response, including providing all requested images, log files, and event information to facilitate rapid resolution of sensitive information incidents. This may involve disconnecting the system processing, storing, or transmitting the sensitive information from the Internet or other networks or applying additional security controls. This may also involve physical access to contractor facilities during a breach/incident investigation [OpDiv insert timeline if required].

D. Position Sensitivity Designations

All Contractor (and/or any subcontractor) employees must obtain a background investigation commensurate with their position sensitivity designation that complies with Parts 1400 and 731 of Title 5, Code of Federal Regulations (CFR). The following position sensitivity designation levels apply to this solicitation/contract:

The requiring activity representative, in conjunction with Personnel Security, shall use the OPM Position Sensitivity Designation automated tool (<https://www.opm.gov/investigations/>) to determine the sensitivity designation for background investigations. After making those determinations, include all applicable position sensitivity designations.

E. Homeland Security Presidential Directive (HSPD)-12

The Contractor (and/or any subcontractor) and its employees shall comply with Homeland Security Presidential Directive (HSPD)-12, *Policy for a Common Identification Standard for Federal Employees and Contractors*; OMB M-05-24; FIPS 201, *Personal Identity Verification (PIV) of Federal Employees and Contractors*; HHS HSPD-12 policy; and *Executive Order 13467, Part 1 §1.2*.

For additional information, see HSPD-12 policy at: <https://www.dhs.gov/homeland-security-presidential-directive-12>

Roster. The Contractor (and/or any subcontractor) shall submit a roster by name, position, e-mail address, phone number and responsibility, of all staff working under this acquisition where the Contractor will develop, have the ability to access, or host and/or maintain a government information system(s). The roster shall be submitted to the COR and/or CO within [OpDiv Specific timeline] of the effective date of this contract. Any revisions to the roster as a result of staffing changes shall be submitted within [OpDiv Specific timeline] of the change. The COR will notify the Contractor of the

appropriate level of investigation required for each staff member. *[If the OpDiv has an electronic template, include that information here along with a link, if applicable.]*

If the employee is filling a new position, the Contractor shall provide a position description and the Government will determine the appropriate suitability level.

F. Contract Initiation and Expiration

- 1) **General Security Requirements.** The Contractor (and/or any subcontractor) shall comply with information security and privacy requirements, Enterprise Performance Life Cycle (EPLC) processes, HHS Enterprise Architecture requirements to ensure information is appropriately protected from initiation to expiration of the contract. All information systems development or enhancement tasks supported by the contractor shall follow the HHS EPLC framework and methodology or *[insert OpDiv-specific requirement]* and in accordance with the HHS Contract Closeout Guide (2012).

HHS EA requirements may be located here:
<https://www.hhs.gov/ocio/ea/documents/proplans.html>

- 2) **System Documentation.** Contractors (and/or any subcontractors) must follow and adhere to NIST SP 800-64, *Security Considerations in the System Development Life Cycle*, at a minimum, for system development and provide system documentation at designated intervals (specifically, at the expiration of the contract) within the EPLC that require artifact review and approval.
- 3) **Sanitization of Government Files and Information.** As part of contract closeout and at expiration of the contract, the Contractor (and/or any subcontractor) shall provide all required documentation *[enter OpDiv-specific requirements]* to the CO and/or COR to certify that, at the government's direction, all electronic and paper records are appropriately disposed of and all devices and media are sanitized in accordance with NIST SP 800-88, *Guidelines for Media Sanitization*.
- 4) **Notification.** The Contractor (and/or any subcontractor) shall notify the CO and/or COR and system ISSO within *[OpDiv-specific timeline]* before an employee stops working under this contract.
- 5) **Contractor Responsibilities Upon Physical Completion of the Contract.** The contractor (and/or any subcontractors) shall return all government information and IT resources (i.e., government information in non-government-owned systems, media, and backup systems) acquired during the term of this contract to the CO and/or COR. Additionally, the Contractor shall provide a certification that all government information has been properly sanitized and purged from Contractor-owned systems, including backup systems and media used during contract performance, in accordance with HHS and/or *[OpDiv]* policies.
- 6) The Contractor (and/or any subcontractor) shall perform and document the actions identified in the ***[OpDiv]*** Contractor Employee Separation Checklist *[insert links to OpDiv form]* when an

employee terminates work under this contract within *[insert OpDiv-specific timeline]* days of the employee's exit from the contract. All documentation shall be made available to the CO and/or COR upon request.

G. Records Management and Retention

The Contractor (and/or any subcontractor) shall maintain all information in accordance with Executive Order 13556 -- Controlled Unclassified Information, National Archives and Records Administration (NARA) records retention policies and schedules and HHS/[OpDiv] policies and shall not dispose of any records unless authorized by HHS/[OpDiv].

In the event that a contractor (and/or any subcontractor) accidentally disposes of or destroys a record without proper authorization, it shall be documented and reported as an incident in accordance with HHS/[OpDiv] policies.

FAR clause 52.239-1, Privacy or Security Safeguards (Section 2.A.2.b.)

2. HHSAR Clause 352.224-71** (Section 2.A.2.e.)

3. FAR 7.105(b)(5) (Section 2.A.7.)

4. FAR 11.002(g) (Section 2.A.7.)

5. FAR 52.239-1(c) (Section 2.D.3.b.)

6. FAR Subpart 4.13 (Section 2.F)

7. FAR Subpart 52.204-9 (Section 2.F)

48 CFR Part 52 - Solicitation Provisions and Contract Clauses at Subpart 52.2 – Text of Provisions and Clauses

48 CFR § 52.224-1 Privacy Act Notification.

As prescribed in [24.104](#), insert the following clause in solicitations and contracts, when the design, development, or operation of a system of records on individuals is required to accomplish an agency function:

PRIVACY ACT NOTIFICATION (APR 1984)

The Contractor will be required to design, develop, or operate a system of records on individuals, to accomplish an agency function subject to the Privacy Act of 1974, Public Law 93-579, December 31, 1974 ([5 U.S.C. 552a](#)) and applicable agency regulations. Violation of the Act may involve the imposition of criminal penalties.

48 CFR § 52.224-2 Privacy Act.

As prescribed in [24.104](#), insert the following clause in solicitations and contracts, when the design, development, or operation of a system of records on individuals is required to accomplish an agency function:

PRIVACY ACT (APR 1984)

(a) The Contractor agrees to—

(1) Comply with the Privacy Act of 1974 (the Act) and the agency rules and regulations issued under the Act in the design, development, or operation of any system of records on individuals to accomplish an agency function when the contract specifically identifies—

(i) The systems of records; and

(ii) The design, development, or operation work that the contractor is to perform;

(2) Include the Privacy Act notification contained in this contract in every solicitation and resulting subcontract and in every subcontract awarded without a solicitation, when the work statement in the proposed subcontract requires the redesign, development, or operation of a system of records on individuals that is subject to the Act; and

(3) Include this clause, including this paragraph (3), in all subcontracts awarded under this contract which requires the design, development, or operation of such a system of records.

(b) In the event of violations of the Act, a civil action may be brought against the agency involved when the violation concerns the design, development, or operation of a system of records on individuals to accomplish an agency function, and criminal penalties may be imposed upon the officers or employees of the agency when the violation concerns the operation of a system of records on individuals to accomplish an agency function. For purposes of the Act, when the contract is for the operation of a system of records on individuals to accomplish an agency function, the Contractor is considered to be an employee of the agency.

(c)(1) “Operation of a system of records,” as used in this clause, means performance of any of the activities associated with maintaining the system of records, including the collection, use, and dissemination of records.

(2) “Record,” as used in this clause, means any item, collection, or grouping of information about an individual that is maintained by an agency, including, but not limited to, education, financial transactions, medical history, and criminal or employment history and that contains the person’s name, or the identifying number, symbol, or other identifying particular assigned to the individual, such as a fingerprint or voiceprint or a photograph.

(3) “System of records on individuals,” as used in this clause, means a group of any records under the control of any agency from which information is retrieved by the name of the individual or by some identifying number, symbol, or other identifying particular assigned to the individual.

48 CFR § 52.239-1 Privacy or Security Safeguards.

As prescribed in [39.106](#), insert a clause substantially the same as the following:

Privacy or Security Safeguards (Aug 1996)

(a) The Contractor shall not publish or disclose in any manner, without the Contracting Officer’s written consent, the details of any safeguards either designed or developed by the Contractor under this contract or otherwise provided by the Government.

(b) To the extent required to carry out a program of inspection to safeguard against threats and hazards to the security, integrity, and confidentiality of Government data, the Contractor shall afford the Government access to the Contractor’s facilities, installations, technical capabilities, operations, documentation, records, and databases.

(c) If new or unanticipated threats or hazards are discovered by either the Government or the Contractor, or if existing safeguards have ceased to function, the discoverer shall immediately bring the situation to the attention of the other party.

48 CFR Part 352 – Solicitation Provisions and Contract Clauses at Subpart 352.2 – Texts of Provisions and Clauses

48 CFR § 352.224-70 Privacy Act.

As prescribed in HHSAR [324.105\(a\)](#), the Contracting Officer shall insert the following clause:

Privacy Act (December 18, 2015)

This contract requires the Contractor to perform one or more of the following: (a) design; (b) develop; or (c) operate a Federal agency system of records to accomplish an agency function in accordance with the Privacy Act of 1974 (Act) (5 U.S.C. 552a(m)(1)) and applicable agency regulations.

The term **system of records** means a group of any records under the control of any agency from which information is retrieved by the name of the individual or by some identifying number, symbol, or other identifying particular assigned to the individual. Violations of the Act by the Contractor and/or its employees may result in the imposition of criminal penalties (5 U.S.C. 552a(i)).

The Contractor shall ensure that each of its employees knows the prescribed rules of conduct in 45 CFR part 5b and that each employee is aware that he/she is subject to criminal penalties for violation of the Act to the same extent as Department of Health and Human Services employees. These provisions also apply to all subcontracts the Contractor awards under this contract which require the design, development or operation of the designated system(s) of records (5 U.S.C. 552a(m)(1)). The contract work statement:

(a) Identifies the system(s) of records and the design, development, or operation work the Contractor is to perform; and

(b) Specifies the disposition to be made of such records upon completion of contract performance.

48 CFR § 352.224-71 Confidential Information.

As prescribed in [HHSAR 324.105\(b\)](#), insert the following clause:

Confidential Information (December 18, 2015)

(a) Confidential Information, as used in this clause, means information or data of a personal nature about an individual, or proprietary information or data submitted by or pertaining to an institution or organization.

(b) Specific information or categories of information that the Government will furnish to the Contractor, or that the Contractor is expected to generate, which are confidential may be identified elsewhere in this contract. The Contracting Officer may modify this contract to identify Confidential Information from time to time during performance.

(c) Confidential Information or records shall not be disclosed by the Contractor until:

(1) Written advance notice of at least 45 days shall be provided to the Contracting Officer of the Contractor's intent to release findings of studies or research, to which an agency response may be appropriate to protect the public interest or that of the agency.

(2) For information provided by or on behalf of the government,

(i) The publication or dissemination of the following types of information are restricted under this contract: Personally Identifiable Information, Protected Health Information.

(ii) The reason(s) for restricting the types of information identified in subparagraph (i) is/are: It is protected under the Privacy Act and HIPAA Privacy and Security rules.

(iii) Written advance notice of at least 45 days shall be provided to the Contracting Officer of the Contractor's intent to disseminate or publish information identified in subparagraph (2)(i). The contractor shall not disseminate or publish such information without the written consent of the Contracting Officer.

(d) Whenever the Contractor is uncertain with regard to the confidentiality of or a property interest in information under this contract, the Contractor should consult with the Contracting Officer prior to any release, disclosure, dissemination, or publication.

TAXES

THE DEPARTMENT OF HEALTH AND HUMAN SERVICES, PHOENIX AREA INDIAN HEALTH SERVICE IS TAX EXEMPT UNDER A.R.S. 42-5063(C)(3)(a), 42-5067 (B)(1), 42-5065(B)(2)(a), 42-5066(B)(3)(a), 42-5074(B)(7), 42-5071(B)(2)(a), 42-5061(A)(25)(a), AND 42-5159(A)(13)(a), (b), (c) STATE OF ARIZONA DEPARTMENT OF REVENUE.